

CODE REVIEW REPORT

BACKEND & AUTHORIZATION

PASS

This is an engineering review of the whole codebase: architecture, every public Convex function, table rules, auth, locks, and rate limiting. Every claim names a real file and symbol so you can verify it yourself.

DOCUMENT ID

CMA-CRR-004

DATE

01 Sep 2026

00

CONTENTS

1 Architecture overview

2 Function inventory

3 Encapsulation and inheritance

4 Table rules

5 How Convex works

6 Validators and locks

HOW TO READ

Every claim names a real file and symbol so you can verify it yourself. Tables list the authoritative source in `convex/` and `src/lib/`.

1

ARCHITECTURE OVERVIEW

STACK

The app is React 19 with TanStack Start on the frontend and Convex on the backend. TypeScript throughout (tsgo, version 7). Bun is the runner. Vite with the Nitro/Vercel adapter handles SSR.

Browser	Edge / SSR	Data plane
React 19 + TanStack Start (TypeScript tsgo, Tailwind v4 tokens via app.css)	TanStack Router file routes src/routes/*.tsx (+ layout) loaders call Convex queries mutations via useMutation Convex Auth Password provider	Convex backend convex/*.ts documents + indexes queries / mutations / actions authTables (sessions, accounts)

File routes. Every file under `src/routes` is a route. `src/routes/service/job.$id.tsx` is the job detail page. `src/routes/admin/audit.tsx` is the audit log. `src/routes/auth/login.tsx` is login. The router tree is generated in `src/routeTree.gen.ts` and never hand-edited. Layouts in `__root.tsx` and `_app.tsx` provide the app shell, auth gating via `useConvexAuth` and `useCurrentUser`, and the inactivity warning modal. Route loaders read `convex/users.ts:me` and `sessionFlags` to force redirects for `mustChangePassword` and `totpExpired`.

Styling. Tailwind v4 tokens live in `src/app.css` as semantic CSS variables: `ink`, `body`, `mute`, `accent`, `bg`, `surface`, `line`, with `.dark` overrides. No hard-coded hex in components.

Backend. One file per domain in `convex/`, plus shared helpers in `convex/lib/`. The full map is below.

REQUEST LIFECYCLE

Here is what happens when someone clicks a button that writes data, say “Generate Final Invoice”:

1. UI call. The component calls `useGenerateInvoiceMutation()` from `src/lib/queries.ts`, which wraps `useMutation(api.invoices.generate)`. Reads work the same way: `useQuery(jobQueries.detail(jobId))` subscribes to `convex/jobs.ts:getDetail`.
2. Convex client. The Convex React client (set up in `src/lib/convex.ts`) sends the call over WebSocket or HTTP to the deployment, with the auth JWT from Convex Auth attached.
3. Auth. The first line of the handler is almost always `await requireActiveSession(ctx, [...])` or `await requireRole(ctx, [...])` or at least `await requireUser(ctx)`. These call `getAuthUserId(ctx)`, fetch the user document, and check `active !== false`, the `lastActiveTs` inactivity window, and 2FA status. On failure they throw a `ConvexError` and the client gets a typed error.
4. Rate limit. Right after auth: `await enforce(ctx, class)`. This reads `rateLimits.by_key_window` for the user, class, and current window. If the bucket is full it throws `ConvexError({code: 'RATE_LIMITED', retryAfterMs})`. No writes have happened yet at this point.
5. Validation. Zod `Schema.parse(args)` from `src/lib/schemas/*` runs inside the handler. Convex `v.*` validators on the function args run even earlier, before the handler body starts. If either fails, the mutation throws before touching the database.

6. Business guards. Things like `findApprovedFinalForJob`, `assertNotLocked`, `canTransition`, plate regex, stock checks, name similarity dedup. Thrown `ConvexError`s become toasts on the client.
7. Writes. `ctx.db.insert`, `patch`, or `delete`. Each mutation is one ACID transaction. If any throw happens after a write, the whole thing rolls back. One documented caveat: the best-effort `rateLimitEvents` insert also rolls back, so the durable signal for a rate-limited call is the thrown error, not the event row.
8. Audit. `await audit(ctx, action, entity, entityId)` inserts into `auditLogs`, still inside the same transaction, so it commits with the business write.
9. Return and reactivity. The return value goes back to the caller. `queryClient.invalidateQueries()` refreshes TanStack Query caches. Convex subscriptions also push updated query results to every subscribed client automatically.

```
Button click → useMutation(api.x.y) → Convex client (+JWT)
  → handler: require* → enforce → Zod+v → business guard → db.* → audit → return
  → TanStack invalidation + Convex subscription push → UI re-renders
```

CONVEX/ MODULE MAP

FILE	DOMAIN	EXPORTS
<code>convex/schema.ts</code>	schema	All tables, indexes, searchIndexes
<code>convex/lib/auth.ts</code>	auth	<code>getCurrentUser</code> , <code>requireUser</code> , <code>requireRole</code> , <code>isValidRole</code>
<code>convex/lib/session.ts</code>	session/2FA	<code>heartbeat</code> , <code>requireActiveSession</code> , <code>sessionFlags</code>
<code>convex/lib/audit.ts</code>	audit	<code>audit</code> logging function
<code>convex/lib/rateLimit.ts</code>	throttling	<code>enforce</code> , <code>enforceDedup</code> , <code>windowStartFor</code> , <code>isRateLimitEnabled</code>
<code>convex/lib/invoiceHelpers.ts</code>	invoicing	<code>buildLineItemsForJob</code> , <code>nextInvoiceNumber</code> , <code>assertNotLocked</code> , <code>findApprovedFinalForJob</code>
<code>convex/lib/totp.ts</code>	2FA crypto	TOTP generation, verification, and backup codes
<code>convex/auth.ts</code>	Convex Auth	<code>convexAuth({providers: [Password]})</code>
<code>convex/auth.config.ts</code>	auth config	Auth provider config
<code>convex/http.ts</code>	HTTP router	<code>httpRouter</code> , auth HTTP routes
<code>convex/crons.ts</code>	crons	Rate limit cleanup daily at 03:00 UTC
<code>convex/migrations.ts</code>	migrations	Schema cleanup helpers (legacy fields)
<code>convex/users.ts</code>	users/admin	User queries and admin mutations
<code>convex/twoFactor.ts</code>	2FA flows	TOTP setup, verify, disable, backup codes
<code>convex/customers.ts</code>	service/customers	Customer CRUD with phone dedup

FILE	DOMAIN	EXPORTS
<code>convex/vehicles.ts</code>	inventory	Vehicle CRUD with plate normalization
<code>convex/ vehicleBrands.ts</code>	brands	Brand management
<code>convex/parts.ts</code>	parts	Parts inventory and stock movements
<code>convex/jobs.ts</code>	jobs	Service jobs lifecycle
<code>convex/appointments.ts</code>	appointments	Appointment scheduling
<code>convex/invoices.ts</code>	invoicing	Invoice generation, approval, locking
<code>convex/payments.ts</code>	payments	Payment recording
<code>convex/leads.ts</code>	sales/leads	Sales lead management
<code>convex/salesOrders.ts</code>	sales/orders	Sales order lifecycle
<code>convex/deliveries.ts</code>	sales/deliveries	Delivery completion
<code>convex/labourTypes.ts</code>	labour	Labour type management
<code>convex/settings.ts</code>	settings	Global settings (VAT rate)
<code>convex/rateLimit.ts</code>	throttling admin	Rate limit inspection and control
<code>convex/activityLogs.ts</code>	activity	Activity logging and audit
<code>convex/auditLogs.ts</code>	audit	Audit log inspection
<code>convex/seed.ts</code>	demo data	Seed data for development
<code>convex/ backfillPlates.ts</code>	migration	Plate normalization backfill

Zod schemas live in `src/lib/schemas/*` and are imported by both client forms and Convex handlers.

2 FUNCTION INVENTORY

This section lists every public function in `convex/` with its auth gate, validators, and rate-limit class.

SHARED HELPERS IN `CONVEX/LIB/`

HELPER	PURPOSE	CALLED BY
<code>getCurrentUser(ctx)</code>	Fetch current user doc	Auth checkers, audit, rate limit
<code>requireUser(ctx)</code>	Require authenticated user	All queries, most mutations
<code>requireRole(ctx, roles)</code>	Require specific role	Admin/privileged mutations
<code>requireActiveSession(ctx, roles)</code>	Require role + active session + 2FA	All write mutations
<code>sessionFlags(ctx)</code>	Get session state flags	<code>users.me</code> for client gating
<code>heartbeat(ctx)</code>	Update last active timestamp	Called every 60s by client
<code>audit(ctx, action, entity, entityId)</code>	Log to audit trail	Every successful mutation
<code>enforce(ctx, class)</code>	Rate limit check	Every public mutation
<code>enforceDedup(ctx, fingerprint, windowMs)</code>	Deduplication check	<code>payments.record</code>
<code>buildLineItemsForJob(ctx, jobId)</code>	Build invoice line items	Invoice and job mutations
<code>nextInvoiceNumber(ctx, kind)</code>	Get next invoice number	Invoice generation
<code>assertNotLocked(invoice)</code>	Verify invoice not locked	Mutations that modify invoices
<code>findApprovedFinalForJob(ctx, jobId)</code>	Find approved final invoice	Job and payment mutations

`CONVEX/USERS.TS`

SYMBOL	KIND	GATE	RATE-LIMIT
<code>me</code>	query	User required	
<code>adminExists</code>	query	User required	
<code>list</code>	query	Admin or audit	
<code>heartbeat</code>	mutation	User required	
<code>setRole</code>	mutation	Admin	admin (5/min)

SYMBOL	KIND	GATE	RATE-LIMIT
<code>setActive</code>	mutation	Admin	admin (5/min)
<code>bootstrapFirstAdmin</code>	mutation	No prior admin	admin (5/min)
<code>adminResetPassword</code>	mutation	Admin	admin (5/min)
<code>changePassword</code>	mutation	User required	admin (5/min)
<code>clearMustChangePassword</code>	mutation	User required	standard (60/min)

CONVEX/TWOFACOR.TS

SYMBOL	KIND	GATE	RATE-LIMIT
<code>status</code>	query	User required	
<code>setup</code>	mutation	User required	admin (5/min)
<code>verifySetup</code>	mutation	User required	standard (60/min)
<code>verifyLogin</code>	mutation	User required	standard (60/min)
<code>disable</code>	mutation	User required	admin (5/min)
<code>regenerateBackupCodes</code>	mutation	User required	admin (5/min)
<code>adminReset</code>	mutation	Admin	admin (5/min)

CONVEX/CUSTOMERS.TS

SYMBOL	KIND	GATE	RATE-LIMIT	GUARD
<code>search</code>	query	User		Text or phone search
<code>get</code>	query	User		Single customer
<code>getWithVehicles</code>	query	User		Hydrate vehicles
<code>create</code>	mutation	Active session	standard	Phone dedup + Levenshtein
<code>update</code>	mutation	Active session	standard	Phone guard if changed

CONVEX/VEHICLES.TS

SYMBOL	KIND	GATE	RATE-LIMIT	GUARD
<code>get</code>	query	User		
<code>byCustomer</code>	query	User		Index by owner

SYMBOL	KIND	GATE	RATE-LIMIT	GUARD
byPlate	query	User		Normalize + lookup
inventory	query	User		All vehicles
create	mutation	Active session	standard	Plate regex validation
adjustStock	mutation	Active session	standard	Non-negative guard
update	mutation	Active session	standard	Plate if present

CONVEX/PARTS.TS

SYMBOL	KIND	GATE	RATE-LIMIT	GUARD
list/get/search	query	User		
lowStock	query	User		Reorder level filter
categories/brands	query	User		Distinct values
createPart	mutation	Active session	standard	Schema validate
updatePart	mutation	Active session	standard	Schema validate
adjustStock	mutation	Active session	standard	Non-negative, log movement
importParts	mutation	Active session	bulk (5/min)	Loop-validate each row

CONVEX/JOBS.TS

SYMBOL	KIND	GATE	RATE-LIMIT	GUARD
getDetail	query	User		Hydrate full job
byStatus	query	User		Status filter + order
openCount	query	User		Not completed/paid
dashboardSummary	query	User		7-day trends
byCustomer	query	User		Customer filter
checkIn	mutation	Active session	standard	Vehicle + customer exist
diagnose	mutation	Active session	standard	Status transition
markReady	mutation	Active session	standard	Status transition
complete	mutation	Active session (manager+)	standard	Manager role required
markPaid	mutation	Active session (finance+)	financial (20/min)	Invoice approved + balance

SYMBOL	KIND	GATE	RATE-LIMIT	GUARD
<code>reverseReady</code>	mutation	Active session	standard	No approved final invoice
<code>addJobItem</code>	mutation	Active session	standard	Invoice not locked
<code>removeJobItem</code>	mutation	Active session	standard	Invoice not locked

CONVEX/INVOICES.TS

SYMBOL	KIND	GATE	RATE-LIMIT	GUARD
<code>getByJob</code>	query	User		Pick approved final
<code>listByJob</code>	query	User		All for job
<code>listBySalesOrder</code>	query	User		All for order
<code>getById</code>	query	User		Single invoice
<code>generate</code>	mutation	Active session (finance+)	financial (20/min)	No approved final
<code>generateSales</code>	mutation	Active session (sales+)	financial (20/min)	Sales domain
<code>regenerate</code>	mutation	Active session (finance+)	financial (20/min)	Not locked
<code>approve</code>	mutation	Active session (finance+)	financial (20/min)	Sets locked=true
<code>createEstimate</code>	mutation	Active session (csr+)	financial (20/min)	Draft estimate
<code>updateEstimate</code>	mutation	Active session (csr+)	financial (20/min)	Draft only
<code>approveEstimate</code>	mutation	Active session (finance+)	financial (20/min)	Estimates stay unlocked
<code>rejectEstimate</code>	mutation	Active session (finance+)	financial (20/min)	Draft to rejected
<code>convertEstimateToFinal</code>	mutation	Active session (finance+)	financial (20/min)	Approved estimate only
<code>adminUnlock</code>	mutation	Admin	financial (20/min)	Sets locked=false

CONVEX/PAYMENTS.TS

SYMBOL	KIND	GATE	RATE-LIMIT	GUARD
<code>byInvoice</code>	query	User		
<code>record</code>	mutation	Active session (finance+)	financial + 60s dedup	Final + approved + balance cap

CONVEX/APPOINTMENTS.TS

SYMBOL	KIND	GATE	RATE-LIMIT
list/listRange/upcoming/get	query	User	
create	mutation	Active session	standard
markCheckedIn	mutation	Active session	standard
cancel	mutation	Active session	standard

CONVEX/LEADS.TS

SYMBOL	KIND	GATE	RATE-LIMIT
list/search/get	query	User	
create	mutation	Active session	standard
updateStage	mutation	Active session	standard
logFollowUp	mutation	Active session	standard

CONVEX/SALESORDERS.TS

SYMBOL	KIND	GATE	RATE-LIMIT
get/list/byVehicle/byLead	query	User	
create	mutation	Active session	financial
complete	mutation	Active session	financial
cancel	mutation	Active session	financial
addPayment	mutation	Active session	financial

CONVEX/DELIVERIES.TS

SYMBOL	KIND	GATE	RATE-LIMIT
get/getBySalesOrder	query	User	
complete	mutation	Active session (sales+)	financial

CONVEX/LABOURTYPES.TS

SYMBOL	KIND	GATE	RATE-LIMIT
<code>list</code>	query	User	
<code>create/update/remove</code>	mutation	Active session (manager+)	financial

CONVEX/SETTINGS.TS

SYMBOL	KIND	GATE	RATE-LIMIT
<code>get</code>	query	User	
<code>setVatRate</code>	mutation	Active session (manager+)	financial

OTHER PUBLIC SURFACES

`convex/rateLimit.ts` : `listEvents` , `getStatus` (admin/audit), `setEnabled` (admin), internal `logEvent` / `cleanup` .

`convex/activityLogs.ts` : `log` (any user), `list` (admin+).

`convex/auditLogs.ts` : `list` , `distinctActions` (admin/audit).

`convex/seed.ts` : `seedData` (mutation), `seed` (action), `checkAuthAccounts` (query).

`convex/vehicleBrands.ts` : `list` (user), `create/update/remove` (manager+, admin rate-limit).

`convex/backfillPlates.ts` : `backfillPlates` (admin only).

`convex/migrations.ts` : `cleanupLegacyJobs` , `cleanupLegacyUsers` (CLI only), `previewLegacyJobs` , `previewLegacyUsers` (read-only preview).

3 ENCAPSULATION AND INHERITANCE

TypeScript and Convex do not have classical OOP class inheritance. Encapsulation here is through module boundaries, closure-enforced invariants, and composition.

WHAT ENCAPSULATION MEANS

MECHANISM	HOW IT WORKS	EXAMPLE
Module boundary	Only <code>export const</code> is callable from client	Helper functions are private to module
Default-deny auth	Every mutation starts with explicit role guard	<code>requireRole(['admin'])</code> returns false for unauthorized
Composition over inheritance	Guards stack without code duplication	<code>requireActiveSession</code> wraps <code>requireRole</code> + inactivity + 2FA
Lib helpers hide invariants	Locking, window math, TOTP crypto in <code>lib/</code>	<code>assertNotLocked</code> , <code>nextInvoiceNumber</code> in one place
Zod + v validators	Wire-level (<code>v</code>) and domain-level (Zod) contracts	<code>v.union</code> on args + <code>Schema.parse</code> in handler
Component composition in React	Hooks and small components, no class inheritance	<code>useInactivity</code> , <code>useCurrentUser</code> , print layouts

WHY NOT CLASSICAL INHERITANCE

A textbook OOP design would introduce `abstract class Mutation` with subclasses. In Convex this breaks for three reasons:

1. Framework constraint. Handlers must be plain `mutation({args, handler})` values. Classes would hide validators from codegen.
2. Transaction scope. Mutations are closures over `ctx`. Subclass dispatch would obscure the atomic boundary.
3. Composition is clearer. `await requireActiveSession(ctx, roles); await enforce(ctx, "financial");` is explicit and auditable. Subclass dispatch fixes ordering in one place and breaks silently if a subclass forgets `super.validate()`.

Concrete composition examples:

Auth stacks: `requireActiveSession` → `requireRole` → `requireUser` → `isAuthorized`.

Rate limiting is one-line reuse: `await enforce(ctx, "financial")` calls `getCurrentUser`, `windowStartFor`, checks the shard doc. No base class needed.

Invoice building stacks: `buildLineItemsForJob` and `buildLineItemsForSalesOrder` are standalone helpers reused across `invoices.*` and `jobs.syncInvoiceForJob`. No `InvoiceBuilder` class hierarchy.

What is NOT here: no `extends`, no `super`, no mixins. Encapsulation is narrow public API, private helpers, and composed guards.

4 TABLE RULES

All tables are defined in `convex/schema.ts:defineSchema`. The `authTables` spread comes first.

CORE TABLES

TABLE	KEY FIELDS	INDEXES	WRITE RULE
<code>users</code>	email, role, active, totpEnabled, backupCodes	email, by_email	Role check + audit
<code>customers</code>	name, phone, email	by_phone, name search	Dedup on phone/ Levenshtein
<code>vehicles</code>	ownerId, plate, make, model, stockQty	by_plate, owner, status	Plate normalize + regex
<code>parts</code>	code, costPrice, sellingPrice, stockQty	by_code, by_brand, by_category	Part-level validation
<code>jobs</code>	vehicleId, customerId, status, complaint	status, by_customer	Status machine via canTransition
<code>invoices</code>	jobId, invoiceNumber, status, locked	by_invoice_number, jobId, salesOrderId	Locked guard after approve
<code>payments</code>	invoiceId, amount, method	by_invoice	Final + approved only
<code>stockMovements</code>	partId, qty, type	by_part	Append-only on stock change
<code>auditLogs</code>	userId, action, entity, entityId	by_entity, by_user, by_ts	Append-only, automatic

SECURITY TABLES

TABLE	KEY FIELDS	INDEXES	USE
<code>rateLimits</code>	key, windowStart, count	by_key_window	Per-user per-class per-minute
<code>rateLimitEvents</code>	userId, actionClass, ts	by_ts, by_action_class	Observability, cleanup cron
<code>activityLogs</code>	userId, event, ts	by_user, by_ts, by_event	User activity tracking
<code>authTables</code>	sessions, accounts, verification codes		Convex Auth managed

SALES/SERVICE TABLES

TABLE	KEY FIELDS	INDEXES	LIFECYCLE
leads	name, phone, stage, interestedVehicleId	stage, name search, phone search	Mutable
salesOrders	vehicleId, leadId, status	by_vehicle, by_lead	Auto-reserve on create
deliveries	salesOrderId, checklist, repld	by_sales_order	One per order
appointments	customerId, status, appointmentTs	by_customer, status, appointmentTs	Scheduled → checked in/ cancelled
labourTypes	name, fixedPrice		Reference table
vehicleBrands	name, normalizedName	by_normalized_name	Uniqueness via normalized

RELATION INTEGRITY

Convex has no declarative foreign keys. FK discipline is enforced in code:

- `jobs.checkIn` verifies `vehicleId` and `customerId` exist
- `salesOrders.create` checks `vehicleId` and `leadId`
- `appointments.create` checks `customerId`
- `jobs.addJobItem` checks `partId` and `labourTypeId`
- `payments.record` checks `invoiceId`

No delete mutations are exposed on any table, so dangling references are not created.

5 HOW CONVEX WORKS

WHAT CONVEX IS

Convex is a reactive backend-as-a-service. You define documents (JSON-like objects) in tables, write server functions, and the client subscribes to query results that push updates automatically. No hand-written REST layer. The deployment runs your `convex/` functions and stores documents in managed storage.

DOCUMENTS

A document is a JSON object with system `_id: Id<Table>` and `_creationTime: number`. Fields are typed by `v.*` validators. Tables are created by `defineTable({...})` in `convex/schema.ts`. Adding a field is additive. Old documents stay readable via `v.optional`. The `authTables` spread contributes `users`, `authSessions`, `authAccounts` for Convex Auth.

TRANSACTIONS

Every `query` or `mutation` handler runs in a single ACID transaction. All `ctx.db` calls are atomic: all commit or none do. If a throw happens after a write, the whole transaction rolls back. Concurrency uses optimistic concurrency control (OCC). Convex does not lock rows on read. If two mutations patch the same document concurrently, one commits and the other retries or fails. This matters for rate limiting: a single global counter would become a hot-row bottleneck, so the shipped design shards per `user:class>windowStart`.

QUERIES VS MUTATIONS VS ACTIONS

KIND	READS	WRITES	TRANSACTIONAL	USE
<code>query</code>	yes	no	read-only, cached, reactive	All <code>list/search/get/by*</code>
<code>mutation</code>	yes	yes	single ACID transaction	Every <code>create/update/approve</code>
<code>action</code>	yes (via runners)	via mutations only	not across the action	Demo data seeding
<code>internalMutation</code>	yes	yes	transaction, not from client	Cron tasks
<code>httpAction</code> / <code>httpRouter</code>				Auth HTTP endpoints

REACTIVE SUBSCRIPTIONS

A `useQuery(api.jobs.getDetail, {jobId})` is not polling. The client opens a subscription. When any document read by that query changes, Convex pushes a fresh result to all subscribers. Dashboard and job detail stay consistent without manual refetch.

SCHEDULER AND CRONS

At 03:00 UTC daily, the cleanup mutation scans rate limit and event tables, deletes old rows. No per-mutation scheduler on hot path.

AUTH

`convex/auth.ts` configures `convexAuth({providers:[Password]})`. User identity in any handler is `getAuthUserId(ctx)`. The `users` table holds profiles plus `totp*`, `lastActiveTs`, `mustChangePassword`. Password hashes live in `authAccounts.secret` (Scrypt), never in `users`.

CLIENT MAPPING

Codegen via `bunx convex codegen` produces `convex/_generated/dataModel.ts` and `api.ts`.

6 VALIDATORS AND LOCKS

VALIDATOR LAYERS

Convex `v` runs before the handler body. Each function declares `args: { field: v.xxx }`. Mismatch returns error to client without entering the transaction.

Examples:

- `jobs.addJobItem` declares `type: v.union(v.literal('part'), v.literal('labour'))`, `partId: v.optional(v.id('parts'))`.
- `payments.record` declares `method: v.union(v.literal('cash'), v.literal('transfer'), ...)`. Enum enforced at wire.
- `parts.adjustStock` derives validators from single `src/lib/enums.ts` source so `v` and Zod stay aligned.

Zod runs inside handler after auth. Most mutations call `Schema.parse(args)` from `src/lib/schemas/*`. This is the domain-level contract: trims, regexes, bounds that `v` alone cannot express. The handler throws `ZodError` if Zod fails, still before `ctx.db.*` write.

Pattern always: `require*` → `enforce` → `Schema.parse` → business guard → `ctx.db.*` → `audit` → return.

INVOICE LOCK MECHANISM

Data field: `invoices.locked?: boolean`. Absent means false.

Trigger 1 - Locking at approve: `invoices.approve` is the only handler that sets `locked:true`. Not `approveEstimate`. Just `approve`. Before the patch, the handler checks invoice is not already approved and is not an estimate. Estimates use `approveEstimate` which patches `status: 'approved'` but does NOT lock.

Trigger 2 - Read as guard: The lock is read at these sites:

- `invoices.generate/regenerate` check `existingFinal` via `assertNotLocked(existingFinal)` or paid
- `invoices.updateEstimate` checks `assertNotLocked(invoice)`
- `jobs.addJobItem/removeJobItem` check `findApprovedFinalForJob` non-null
- `payments.record` rejects `locked && paid`, plus checks balance cap
- `jobs.reverseReady` checks `findApprovedFinalForJob` non-null
- `invoices.convertEstimateToFinal` checks no existing approved final

The helper `findApprovedFinalForJob` returns `kind==='final' && approved`. An approved final is treated as locked even if `locked` field was forgotten. The code double-guards via both `assertNotLocked` and `allInvoices.some(i=>i.locked)`.

Unlock path: `invoices.adminUnlock` is the only mutation that patches `locked:false`. It requires `requireRole(['admin'])`, a reason 10-300 chars, and only works if invoice is actually locked. After unlock, the final becomes `approved:true, locked:false` so further writes are allowed until next `approve`.

`generatedById` tracking: On first `generate` and on `approve`, the final records which user produced or approved it. Queries project `generatedById` only for admin. Non-admin users receive invoice without that field.

RATE-LIMIT CLASSES

Every public mutation throws `RATE_LIMITED` when per-user per-class budget is exhausted. Classes are wired in each mutation (see section 2):

```
await requireActiveSession(ctx, [...])
await enforce(ctx, "financial") // or "admin" | "bulk" | "standard"
const parsed = SomeSchema.parse(args)
```

Classes:

- `admin` 5/min: Users, two-factor setup/disable, vehicle brands, backfill
- `financial` 20/min: Payments, invoices, sales orders, labour types, deliveries, VAT settings
- `bulk` 5/min: Parts import
- `standard` 60/min: Customers, vehicles, leads, appointments, most job mutations, parts CRUD

Queries never call `enforce`. They are read-only and limiting them hurts busy shifts.

Dedup guard: `payments.record` calls `enforceDedup(ctx, 'pay:${invoiceId}:${amount}:${method}')` additionally. An identical payment within 60 seconds throws even if the 20/min bucket permits. Prevents double-click ledger noise.

Window math: `windowStartFor(now, 60000) = floor(now/60000)*60000`. First mutation in a window inserts `{key, windowStart, count:1}`. Later mutations patch `count+1`. At `count >= limit` throw includes `retryAfterMs = ws+60000 - now` for client countdown. Next wall-minute gets fresh doc, no contested reset. Cron at 03:00 UTC prunes `windowStart < now-24h` and old events.

SESSION EXPIRY

`requireActiveSession` throws when `now - lastActiveTs > 30*60*1000`. On client, `useInactivity` debounces events, heartbeats `api.users.heartbeat` every 60 seconds, shows warning at 25 minutes, hard-redirects to `/auth/login?expired=1` at 30 minutes. `users.me` returns `sessionFlags` so router gates `/auth/verify-2fa` and `/auth/change-password`. Until first heartbeat, server allows writes. Once set, every `requireActiveSession` write respects the 30-minute clock. 2FA adds its own `lastTotpVerifiedTs` gate with the same window.
